De contraseñas a passkeys: evolución del inicio de sesión seguro y observabilidad en aplicaciones web, móviles y de escritorio

1 Abstract

In recent years, the digital transformation of enterprises and the exponential growth of cloud-native architectures have fundamentally altered the cybersecurity landscape. Traditional perimeter-based defenses are no longer sufficient to protect sensitive information, making user authentication the primary attack surface for malicious actors. Passwords, functioning as shared secrets, have proven to be a critical vulnerability, leading to a massive surge in credential stuffing, account takeovers (ATO), and sophisticated phishing campaigns. As a result, the industry is witnessing a paradigm shift towards passwordless authentication mechanisms, spearheaded by FIDO2 standards, WebAuthn, and passkeys, which leverage public-key cryptography to provide phishing-resistant security.

Concurrently, the complexity of modern distributed systems—spanning web, mobile, and desktop environments—demands advanced diagnostic capabilities that go beyond traditional monitoring. Monitoring systems, which rely on predefined thresholds, are inherently reactive and often fail to detect sophisticated identity-based attacks that use legitimate but compromised credentials. Observability, powered by the open standards of OpenTelemetry and the kernel-level visibility of the extended Berkeley Packet Filter (eBPF), has emerged as a critical requirement for real-time threat detection, allowing security teams to correlate high-level application intent with low-level system actions.

This paper presents an exhaustive analysis of secure login architectures and full-stack observability tailored for software engineering applications. It explores the integration of modern authentication protocols, such as OAuth 2.0 with Proof Key for Code Exchange (PKCE) and OpenID Connect (OIDC), across diverse platforms, while addressing the specific security challenges inherent to web, mobile, and native desktop environments. Furthermore, it evaluates the regulatory and compliance frameworks, including the updated NIST SP 800-63-4 guidelines , as well as the Colombian legal context concerning data protection (Ley 1581 de 2012) and cybercrimes (Ley 1273 de 2009). The objective is to provide a comprehensive, unbiased, and technically rigorous guide for systems engineering students and practitioners to design, implement, and observe secure authentication flows in contemporary application architectures.

2 Introducción

La evolución de las tecnologías de la información ha transformado radicalmente la forma en que las organizaciones, los ciudadanos y los gobiernos interactúan en el ciberespacio. Históricamente, la seguridad de la información se fundamentaba en la protección de activos físicos y redes perimetrales cerradas, operando bajo la premisa de que todo lo que se encontraba dentro de la red corporativa era inherentemente confiable. Sin embargo, la

proliferación del Internet de las Cosas (IoT), la computación en la nube, los ecosistemas de dispositivos móviles y la migración hacia arquitecturas de microservicios han disuelto por completo las fronteras tradicionales de la red. En este nuevo entorno hiperconectado y descentralizado, el concepto de un perímetro de seguridad estático resulta obsoleto; cada componente del sistema, desde un contenedor efímero hasta un dispositivo personal utilizado bajo el modelo *Bring Your Own Device* (BYOD), representa un riesgo potencial de seguridad que debe ser gestionado, monitoreado y protegido de manera individual.

Ante la desaparición del perímetro de red tradicional, la identidad del usuario se ha erigido como la nueva y definitiva frontera de control y defensa. El proceso de autenticación o inicio de sesión es el mecanismo algorítmico y lógico crítico que determina quién interactúa con el sistema, bajo qué contexto de confianza y con qué nivel de privilegios puede acceder a los activos de información. No obstante, los métodos de autenticación heredados, particularmente aquellos fundamentados en contraseñas estáticas, presentan vulnerabilidades sistémicas insalvables. Las contraseñas, al operar bajo el modelo criptográfico de secreto compartido (*shared secret*), son susceptibles a una vasta gama de vectores de ataque. Desde el *phishing* (suplantación de identidad) y los ataques de diccionario, hasta el *credential stuffing* (relleno de credenciales masivo), donde actores maliciosos automatizan el uso de bases de datos de contraseñas filtradas previamente para comprometer cuentas a escala global.

El ecosistema digital moderno exige, en consecuencia, la adopción imperativa de un enfoque de arquitectura *Zero Trust* (Confianza Cero), el cual se rige por el principio innegociable de "nunca confiar, siempre verificar". En este modelo arquitectónico, la ubicación topológica del usuario —ya sea dentro de la red local de la empresa o a través de una red pública in-segura— no otorga ningún grado de confianza implícita; cada solicitud de acceso debe ser autenticada y autorizada dinámicamente evaluando múltiples señales de riesgo. Para materializar esta visión técnica, el proceso de inicio de sesión debe evolucionar perentoriamente hacia esquemas robustos como la Autenticación Multifactor (MFA) resistente al *phishing* y los sistemas sin contraseñas (*passwordless*), tales como los *passkeys* respaldados por los estándares de la FIDO Alliance y el W3C, que aprovechan la criptografía de clave pública para erradicar las debilidades del secreto compartido.

De manera paralela y simbiótica, la inmensa complejidad de distribuir una aplicación a través de plataformas dispares —web, móviles y aplicaciones de escritorio nativas— genera un desafío operativo de primer orden: la pérdida de visibilidad profunda o "puntos ciegos" en la infraestructura. Cuando se materializa una falla de seguridad, o se inicia un ataque sigiloso de toma de control de cuenta (ATO - *Account Takeover*), las herramientas de monitoreo tradicionales resultan insuficientes. El monitoreo clásico, que se limita a emitir alertas cuando se supera un umbral predefinido de consumo de CPU o latencia de red, es incapaz de identificar la causa raíz de un ataque lógico en un enjambre de cientos de microservicios interdependientes.

Es en este vacío operacional donde interviene decisivamente la observabilidad, una disciplina avanzada de la ingeniería de *software* que permite a los sistemas inferir su estado interno a partir de la correlación de sus salidas externas: métricas, eventos, registros (*logs*) y trazas distribuidas. La integración de tecnologías de vanguardia como OpenTelemetry (un estándar abierto para la instrumentación) y eBPF (*extended Berkeley Packet Filter*, que permite la ejecución de programas de monitorización directamente en el núcleo del sistema operativo sin alterar el código fuente), dota a los equipos de ingeniería y seguridad de una capacidad sin precedentes para rastrear el flujo completo de una transacción de autenticación. Esto facilita la detección de anomalías comportamentales, la identificación de fraudes y la mitigación de amenazas persistentes en tiempo real.

El presente documento aborda de manera exhaustiva la intersección crítica entre la implementación de flujos de inicio de sesión seguro y la observabilidad integral en el desarrollo de *software* contemporáneo. A través de un análisis detallado, se examinarán las tendencias tecnológicas actuales, los marcos normativos y regulatorios (incluyendo las leyes colombianas y los estándares internacionales del NIST), y las consideraciones arquitectónicas de diseño específicas para aplicaciones de escritorio, móviles y web. Esta investigación se estructura como una guía teórica y práctica fundamental para la ingeniería de sistemas, orientada a formar profesionales capaces de diseñar ecosistemas digitales resilientes frente a las amenazas del mañana.

3 Descripción y caracterización del problema

La gestión de identidades, la autorización de accesos y la supervisión de la seguridad en tiempo de ejecución enfrentan un panorama crítico, caracterizado por una asimetría creciente entre la sofisticación de las herramientas utilizadas por los atacantes y las defensas reactivas implementadas por la mayoría de las organizaciones.

3.1 El panorama de la ciberdelincuencia y el fraude de identidad en la era de la hiperconectividad

A nivel global y regional, el volumen de ataques cibernéticos dirigidos a comprometer credenciales de usuario ha alcanzado niveles sin precedentes en la historia de la computación, convirtiéndose en una industria ilícita altamente rentable y estructurada. En el contexto específico de Colombia, las estadísticas recientes proyectan una realidad alarmante que exige una respuesta inmediata por parte de la academia y la industria tecnológica. De acuerdo con los informes oficiales consolidados por el Ministerio de Tecnologías de la Información y las Comunicaciones (MinTIC), durante el año 2024 se documentaron y registraron más de 36.000 millones de intentos de ciberataques en la infraestructura del país. Esta cifra astronómica evidencia la magnitud industrial del riesgo digital y el aumento sostenido de actividades maliciosas automatizadas.

De manera paralela, las denuncias formales por delitos informáticos presentadas ante la Policía Nacional de Colombia y el Centro Cibernético Policial experimentaron un crecimiento interanual del 23%, superando los 77.600 casos documentados. Los vectores iniciales de acceso más frecuentes y perjudiciales continúan siendo las campañas de *phishing* dirigidas, los ataques de *ransomware* (secuestro de datos) y la suplantación de identidad digital. Estas modalidades de ataque han impactado severamente a empresas de todos los tamaños y sectores, pero han sido particularmente devastadoras para las pequeñas y medianas empresas (PyMEs), donde el Equipo de Respuesta a Emergencias Cibernéticas de Colombia (ColCERT) logró identificar más de 22.000 vulnerabilidades críticas expuestas a Internet durante un solo periodo fiscal, reflejando graves brechas en la infraestructura tecnológica y una deficiente preparación interna en materia de ciberseguridad.

A nivel mundial, el fraude derivado de la toma de control de cuentas (ATO, por sus siglas en inglés) genera pérdidas económicas astronómicas, con reportes que indican que los incidentes de ciberseguridad le costarán a la economía global aproximadamente 9.5 billones de dólares anuales. Las investigaciones de la industria confirman que las credenciales robadas, adquiridas en mercados de la red profunda (*Dark Web*), siguen siendo el vector de acceso inicial principal, estando presentes en un porcentaje abrumadoramente alto de las brechas de datos

documentadas. En este ecosistema de amenazas, los ataques de *credential stuffing* se han industrializado. Utilizando inmensas *botnets* e infraestructuras de *proxies* residenciales rotativos para enmascarar el origen del tráfico y evadir las reglas de limitación de tasa (*rate-limiting*), los atacantes prueban masivamente millones de pares de usuario y contraseña. Los análisis de tráfico de red demuestran que, en promedio, el 19% de todos los intentos de autenticación diarios en sistemas corporativos son, en realidad, ataques de relleno de credenciales, llegando a representar hasta un asombroso 44% del tráfico de inicio de sesión durante picos de ataque coordinados. Además, la irrupción de la Inteligencia Artificial generativa ha democratizado la creación de *malware* y facilitado campañas de ingeniería social altamente persuasivas y libres de errores gramaticales, elevando exponencialmente la credibilidad de los correos electrónicos y mensajes de texto fraudulentos.

3.2 Vulnerabilidades estructurales en los esquemas de autenticación heredados

El núcleo del problema de seguridad radica en la confianza continuada, por parte de desarrolladores y arquitectos de *software*, en modelos de autenticación obsoletos. A pesar de la disponibilidad de alternativas criptográficas superiores, los estudios revelan que un alarmante 87% de las organizaciones aún utiliza predominantemente la autenticación basada en contraseñas para sus aplicaciones orientadas al cliente, aun cuando apenas un 2% de los profesionales de seguridad considera que este método logra un equilibrio efectivo entre la protección de los datos y la experiencia del usuario (UX).
El factor humano agrava esta vulnerabilidad técnica. Los usuarios finales, abrumados por la necesidad cognitiva de gestionar decenas o cientos de credenciales, sucumben habitualmente a la fatiga de contraseñas. Investigaciones exhaustivas indican que más de la mitad de los usuarios reutiliza la misma contraseña en un promedio de cinco cuentas diferentes, tanto en el ámbito personal como corporativo. Esta práctica de reciclaje de credenciales significa que la vulnerabilidad de un sistema periférico o de bajo valor (por ejemplo, un foro de discusión o una aplicación de comercio electrónico poco segura) compromete de manera directa e inmediata la seguridad de plataformas críticas, como la banca en línea o el acceso a redes empresariales.
El Proyecto Abierto de Seguridad de Aplicaciones Web (OWASP), el estándar de facto en la industria para la clasificación de vulnerabilidades, subraya repetidamente la gravedad de este problema. En su riguroso listado *OWASP Top 10* para aplicaciones web y móviles, las fallas de identificación y autenticación (categoría A07:2021), así como las fallas en el control de acceso (*Broken Access Control*, categoría A01:2021), se posicionan como los riesgos de seguridad más prevalentes y de mayor impacto. En el ámbito de desarrollo práctico, estas vulnerabilidades se manifiestan a través de arquitecturas deficientes que permiten:

- Políticas de contraseñas permisivas que facilitan ataques de fuerza bruta y ataques de diccionario.
- Prácticas de almacenamiento inseguro de credenciales en las bases de datos, como el uso de algoritmos de *hashing* obsoletos (MD5, SHA-1) o la ausencia de técnicas de *salting* criptográfico.
- Gestión deficiente del ciclo de vida de la sesión, manifestada en *tokens* de acceso con tiempos de expiración excesivamente prolongados, incapacidad técnica para revocar sesiones activas desde el servidor, o vulnerabilidades de fijación de sesión.
- Implementaciones superficiales o defectuosas de Autenticación Multifactor (MFA) que, si bien añaden un obstáculo, siguen siendo vulnerables a ataques de fatiga (*MFA bombing*)

o a sofisticados ataques de *phishing* de proxy inverso (AiTM - *Adversary-in-the-Middle*), donde el atacante intercepta en tiempo real tanto la contraseña como el código temporal OTP ingresado por el usuario.

3.3 El abismo semántico: La dicotomía entre el Monitoreo Tradicional y la Observabilidad

Incluso en escenarios donde las organizaciones logran implementar controles perimetrales robustos y esquemas de autenticación reforzados, enfrentan un problema analítico profundo: la incapacidad sistemática para detectar accesos no autorizados o comportamientos anómalos de manera oportuna. En las arquitecturas modernas —que han abandonado los servidores monolíticos en favor de clústeres dinámicos de Kubernetes, contenedores de vida efímera, funciones *serverless* y despliegues multinube — las herramientas de monitoreo tradicional son operativamente ciegas ante los patrones de ataque contemporáneos.

El paradigma de monitoreo clásico se fundamenta en la recopilación de métricas de infraestructura básicas y la evaluación del estado de un componente frente a un umbral estático predefinido (por ejemplo, disparar una alerta si la utilización de la CPU supera el 90% o si se detecta un pico volumétrico de tráfico en un puerto específico). Este enfoque es eminentemente reactivo; está diseñado para responder a la pregunta de "qué componente falló", basándose exclusivamente en el reconocimiento de "problemas conocidos" (*known unknowns*). Sin embargo, cuando un atacante elude la fase inicial de autenticación utilizando credenciales legítimas pero previamente comprometidas en una brecha externa, el sistema no registra ninguna anomalía a nivel de red o de procesador. El atacante puede proceder a acceder a una API interna, elevar sus privilegios y exfiltrar gigabytes de información sensible, mientras que los indicadores tradicionales de salud del servidor (CPU, memoria, disco) permanecen en niveles normales.

Esta grave limitación es catalogada explícitamente en el *OWASP Top 10* bajo la categoría de Fallas en el Registro y Monitoreo de Seguridad (*Security Logging and Monitoring Failures* - A09:2021). Las aplicaciones carecen crónicamente de la capacidad arquitectónica para trazar y correlacionar un evento de inicio de sesión geográficamente inusual con una consulta destructiva a la base de datos realizada fracciones de segundo después. Este "abismo semántico" entre la intención lógica de alto nivel (por ejemplo, la ejecución de una rutina de inicio de sesión) y las acciones de bajo nivel del sistema operativo (llamadas al *kernel*, apertura de conectores de red, manipulación del sistema de archivos) impide a los equipos de ingeniería de seguridad distinguir eficazmente entre el comportamiento operativo de un usuario legítimo y las tácticas de exfiltración o el movimiento lateral ejecutado por un ciberdelincuente.

4 Objetivos

4.1 Objetivo general

Proponer, estructurar y fundamentar un marco teórico y arquitectónico comprensivo para el diseño e implementación de flujos de inicio de sesión seguro y *pipelines* de observabilidad profunda en aplicaciones de escritorio, móviles y web, garantizando la alineación estricta con las mejores prácticas internacionales de ciberseguridad, los estándares de la industria, y el cumplimiento riguroso del marco normativo colombiano.

4.2 Objetivos específicos

- Investigar y documentar la evolución técnica de la autenticación digital, evaluando críticamente la transición ineludible desde los modelos vulnerables basados en contraseñas estáticas hacia las arquitecturas de *Zero Trust*, la MFA resistente al *phishing*, y la implementación de *passkeys* fundamentados en los estándares FIDO2 y WebAuthn.
- Analizar en profundidad el paradigma de la observabilidad moderna (impulsado por tecnologías de código abierto como OpenTelemetry y eBPF) contrastándolo con el monitoreo tradicional, y detallar mecánicamente su capacidad para correlacionar telemetría y detectar fraudes de identidad, tomas de control de cuentas y movimientos laterales en tiempo real.
- Diferenciar y establecer las estrategias criptográficas de seguridad, los métodos de almacenamiento y gestión de credenciales, y las arquitecturas de autorización requeridas de manera específica según el entorno de despliegue final (plataformas Web, sistemas operativos móviles como iOS/Android, y entornos de escritorio nativos bajo Windows/macOS/Linux).
- Examinar de manera analítica el marco legal colombiano, haciendo especial énfasis en la aplicabilidad de la Ley 1273 de 2009 (Delitos Informáticos) y la Ley 1581 de 2012 (Protección de Datos Personales), para asegurar que el diseño de los sistemas de identificación, así como la recopilación y procesamiento de telemetría de usuarios, cumplan con los imperativos jurídicos nacionales.

5 Marco teórico

La construcción y el desarrollo de sistemas de información inherentemente seguros exigen una comprensión holística y profunda de los fundamentos de ciberseguridad, la aplicación de protocolos criptográficos modernos para la validación de identidades, y el acatamiento de las directrices normativas. Esta sección desglosa el aparato conceptual necesario para abordar la ingeniería de la autenticación y la observabilidad.

5.1 Seguridad de la Información, Gestión de Riesgos y Defensa en Profundidad

Es imperativo establecer que la ciberseguridad es un subconjunto especializado de la Seguridad de la Información, enfocado de manera particular en proteger los activos digitales contra amenazas gestadas y ejecutadas en el ciberespacio, excluyendo explícitamente aspectos como los desastres naturales o la seguridad estrictamente física de las instalaciones, aunque estas áreas se interrelacionen a nivel corporativo. Toda estrategia arquitectónica de seguridad de la información debe pivotar alrededor de la preservación inquebrantable de la tríada CID (o CIA, por sus siglas en idioma inglés), a la que se integran conceptos modernos adicionales:

- **Confidencialidad:** Garantizar que la información sensible sea accesible única y exclusivamente por aquellas entidades (usuarios humanos o servicios automatizados) que cuenten con la autorización explícita y legítima. Este pilar se preserva tecnológicamente mediante la implementación de controles de acceso granulares, gestión de permisos y algoritmos de cifrado de estado del arte (tanto para datos en reposo como en tránsito).

- **Integridad:** Salvaguardar la precisión absoluta, la inmutabilidad y la completitud de los datos y de sus métodos de procesamiento. La integridad se defiende a través de la instrumentación de firmas digitales asimétricas, funciones *hash* criptográficas sólidas (como SHA-256 o superior) y el mantenimiento de registros de auditoría inviolables.
- **Disponibilidad:** Asegurar, mediante principios de diseño resiliente, que los usuarios autorizados cuenten con acceso confiable y oportuno a la información y a los recursos del sistema en el momento en que los requieran, mitigando amenazas como los ataques de Denegación de Servicio (DoS/DDoS).
- **No Repudio:** Un concepto avanzado que proporciona la garantía criptográfica de que una acción o transacción no puede ser negada posteriormente por la entidad que la originó. Se logra mediante el entrelazamiento de firmas digitales con identidades fuertemente verificadas.

El establecimiento de un Sistema de Gestión de Seguridad de la Información (SGSI), cimentado en normativas de alcance global como la ISO/IEC 27001, parte del axioma fundamental de que la seguridad no es un producto que se adquiere e instala, sino un proceso iterativo y continuo de gestión de riesgos. Bajo las directrices de la norma ISO/IEC 27005, el riesgo de seguridad de la información se conceptualiza matemáticamente como la probabilidad de que una amenaza determinada explote una vulnerabilidad existente, causando un impacto negativo mensurable sobre los activos de la organización.

Dado que el riesgo jamás puede ser reducido a cero absoluto, la ingeniería de sistemas emplea la estrategia de **Defensa en Profundidad** (*Defense in Depth*). Este enfoque táctico asume por diseño que ningún control de seguridad individual, por sofisticado que sea, es invulnerable. Por lo tanto, exige la estratificación de múltiples controles superpuestos, conceptualizados frecuentemente como anillos concéntricos o capas secuenciales, que abarcan desde políticas administrativas y seguridad de red perimetral, hasta la seguridad de las aplicaciones y la protección del dispositivo final del usuario. La lógica subyacente es que si un atacante logra comprometer la primera línea de defensa (por ejemplo, mediante el robo de una contraseña en un ataque de *phishing*), las capas subsecuentes (como la exigencia de un *token* de *hardware* MFA, el análisis de comportamiento basado en IA, o la observabilidad de anomalías a nivel de *kernel*) actuarán como barreras independientes para bloquear, retrasar o alertar sobre la progresión de la intrusión.

5.2 Legislación Colombiana: Delitos Informáticos y Privacidad de la Información

El diseño de la arquitectura de inicio de sesión y de los sistemas de recopilación de telemetría no es exclusivamente un problema de ingeniería de *software*; constituye una profunda responsabilidad jurídica y legal. En Colombia, el ecosistema de aplicaciones debe alinearse milimétricamente con dos cuerpos normativos fundamentales que regulan el ciberespacio nacional.

La Ley 1273 de 2009 (Protección de la Información y de los Datos): Esta legislación representa un hito, ya que modificó el Código Penal colombiano para tipificar, clasificar y sancionar penalmente los delitos informáticos, creando un nuevo bien jurídico tutelado. Para los ingenieros de sistemas responsables del diseño de interfaces de autenticación, resultan de vital importancia los siguientes artículos:

- **Artículo 269A (Acceso abusivo a un sistema informático):** Impone penas de prisión sustanciales a quien acceda de forma total o parcial a un sistema informático, protegido o

no, sin autorización o excediendo los límites acordados. En términos de arquitectura, esto exige que el inicio de sesión no se detenga en la mera autenticación (verificar quién es el usuario), sino que esté intrínsecamente ligado a un robusto sistema de autorización, como el Control de Acceso Basado en Roles (RBAC), para impedir que un usuario autenticado escale privilegios o realice un acceso abusivo a segmentos restringidos del sistema.

- **Artículo 269G (Suplantación de sitios web para capturar datos personales):** Castiga la creación, diseño o envío de páginas electrónicas o enlaces fraudulentos con el objetivo de capturar credenciales u otra información personal. Esta disposición legal evidencia la materialidad de la amenaza del *phishing* en Colombia y obliga éticamente a las organizaciones a migrar hacia tecnologías de autenticación que mitiguen de forma algorítmica este riesgo. La implementación de *passkeys* responde directamente a esta necesidad, ya que impiden a nivel de protocolo que un usuario entregue sus credenciales a un dominio criptográficamente no verificado, neutralizando el impacto de los sitios suplantados.
- **Artículo 269I (Hurto por medios informáticos y semejantes):** Sanciona específicamente a quien supere medidas de seguridad informática o suplante a un usuario ante los sistemas de autenticación y autorización establecidos, con el fin de cometer fraude.

La Ley 1581 de 2012 (Ley Estatutaria de Protección de Datos Personales): Esta norma estatutaria desarrolla y regula el derecho fundamental y constitucional al *Habeas Data* (consagrado en el Artículo 15 de la Constitución Nacional), garantizando a todos los ciudadanos el derecho inalienable a conocer, actualizar, rectificar y solicitar la eliminación de la información personal que haya sido recolectada sobre ellos en bases de datos o archivos de entidades públicas o privadas.

- Establece **principios rectores** insoslayables como el principio de finalidad (los datos recolectados durante el inicio de sesión y la telemetría de observabilidad deben utilizarse estricta y exclusivamente para los fines de seguridad que fueron informados al usuario), el principio de libertad (requiriendo el consentimiento previo, expreso e informado para el tratamiento) y el principio de seguridad.
- Bajo el principio de seguridad, la Ley 1581 obliga a los responsables del tratamiento de la información a implementar todas las medidas técnicas, humanas y administrativas necesarias (tales como el cifrado fuerte, arquitecturas de bases de datos resilientes y controles de acceso estrictos) para otorgar seguridad a los registros, evitando su adulteración, pérdida, consulta, uso o acceso no autorizado o fraudulento. En el contexto del inicio de sesión, esto aplica no solo a los correos electrónicos o números de teléfono, sino también a las huellas biométricas, direcciones IP, identificadores de dispositivos y patrones de comportamiento telemétrico recopilados por las herramientas de observabilidad.

5.3 La Evolución de la Autenticación: El Camino Hacia un Mundo "Passwordless"

Durante décadas, el paradigma tradicional de inicio de sesión ha dependido del conocimiento de una cadena de caracteres: el nombre de usuario y la contraseña. Este mecanismo opera bajo el frágil modelo de "secreto compartido" (*shared secret*), el cual estipula que tanto el cliente que solicita el acceso como el servidor que lo concede deben conocer, procesar y

almacenar (idealmente en forma de un *hash* seguro) el mismo dato confidencial. La vulnerabilidad sistémica de este modelo se ha hecho evidente. Si un atacante vulnera la base de datos del servidor, o si engaña al usuario mediante *phishing* para que revele el secreto, la barrera de seguridad colapsa por completo.

Para abordar esta debilidad fundamental, la industria tecnológica ha transitado a través de varias etapas evolutivas:

1. **Autenticación Multifactor (MFA) Básica:** Esta fase introdujo la exigencia de combinar al menos dos factores de autenticación de naturalezas diferentes. Típicamente, algo que el usuario conoce (la contraseña) sumado a algo que el usuario posee (un dispositivo móvil que recibe un mensaje SMS o un código OTP - *One Time Password* generado por una aplicación temporal) o algo que el usuario es (una característica biométrica). Aunque la MFA básica elevó el nivel de dificultad para los atacantes, tecnologías como el SMS han demostrado ser susceptibles a la interceptación, al secuestro del protocolo SS7, o a ataques de clonación de tarjetas SIM (*SIM swapping*). Además, las contraseñas temporales TOTP ingresadas manualmente pueden ser robadas en tiempo real mediante ataques AiTM.
2. **MFA Resistente al Phishing:** Como respuesta a las vulnerabilidades de la MFA básica, surgieron los protocolos de MFA resistente al *phishing*. Estos esquemas utilizan *hardware* criptográfico dedicado (como las llaves de seguridad FIDO U2F físicas) para garantizar que el intento de autenticación proviene de un dispositivo verificado en posesión del usuario y, crucialmente, que la respuesta de autenticación está vinculada criptográficamente de manera inseparable al nombre de dominio real (*Origin*) del sitio web legítimo. Si el usuario es engañado y navega a una URL falsa (por ejemplo, seguridad-banco.com en lugar de banco.com), el *token* de *hardware* se negará a generar la firma criptográfica válida para el sitio fraudulento, abortando el ataque instantáneamente.
3. **Passkeys y el estándar FIDO2:** La evolución definitiva y la tendencia tecnológica dominante proyectada para el año 2025 es la adopción masiva de los *passkeys* (claves de acceso). Fundamentados en la especificación WebAuthn del consorcio W3C y el protocolo CTAP2 de la FIDO Alliance, los *passkeys* proponen la eliminación total de la contraseña como factor humano. En su lugar, reemplazan el secreto compartido por la generación de un par de claves criptográficas asimétricas únicas para cada servicio o dominio web.
    - La **clave privada** (*private key*) se genera de forma segura y se almacena en el módulo criptográfico del dispositivo del usuario (el enclave seguro de un teléfono inteligente o el TPM de una computadora portátil). Esta clave privada jamás abandona el dispositivo y su uso está bloqueado localmente por la biometría del usuario (FaceID, TouchID, Windows Hello) o por un PIN local.
    - La **clave pública** (*public key*) correspondiente se envía y se almacena en el servidor de la aplicación.
    - Durante el proceso de inicio de sesión, el servidor emite un desafío matemático aleatorio (*challenge*). El dispositivo del usuario, tras verificar la intención mediante la biometría local, utiliza su clave privada para firmar criptográficamente el desafío y devolverlo al servidor. El servidor verifica la validez de la firma empleando la clave pública previamente registrada, concediendo el acceso.
    - **Beneficios Cuantitativos:** La adopción de *passkeys* ha demostrado empíricamente una tasa de éxito en los intentos de inicio de sesión superior al 98% (frente a tasas de éxito marcadamente menores para esquemas complejos de

contraseñas), reduce el tiempo de fricción del inicio de sesión hasta en un 80%, y erradica algorítmicamente la posibilidad técnica de sufrir ataques de *credential stuffing*, puesto que simplemente no existen contraseñas almacenadas en los servidores que puedan ser robadas en una brecha de datos.

5.3.1 Lineamientos Normativos del NIST SP 800-63-4

Para estructurar la aplicación de estas tecnologías, el Instituto Nacional de Estándares y Tecnología de los Estados Unidos (NIST) publicó en 2025 la Cuarta Revisión de sus influyentes Directrices de Identidad Digital (NIST Special Publication 800-63-4). Este marco de referencia es el estándar de oro global para el diseño de sistemas de información seguros y establece una taxonomía basada en el riesgo mediante los Niveles de Garantía de Autenticación (AAL - *Authenticator Assurance Levels*) :

- **AAL1:** Provee una garantía de seguridad de nivel básico, requiriendo típicamente autenticación de un solo factor (como una contraseña fuerte). En 2025, el NIST desaconseja enfáticamente la limitación al AAL1 para sistemas que manejen cualquier forma de datos personales o sensibles.
- **AAL2:** Constituye la nueva línea base recomendada para la mayoría de las aplicaciones corporativas y comerciales. Exige la implementación de MFA y promueve proactivamente la transición hacia autenticadores resistentes al *phishing*. De manera crucial, la revisión 4 del estándar integra y autoriza explícitamente el uso de **passkeys sincronizables** en el nivel AAL2. Un *passkey* sincronizable es aquel cuya clave privada puede ser respaldada y sincronizada de manera encriptada a través del ecosistema en la nube del proveedor del sistema operativo (por ejemplo, el llavero de iCloud de Apple o el gestor de contraseñas de Google), mejorando drásticamente la usabilidad y la recuperación de cuentas si el usuario pierde su dispositivo.
- **AAL3:** Representa el máximo nivel de garantía posible, reservado imperativamente para operaciones altamente críticas (infraestructura gubernamental, sistemas transaccionales financieros de alto valor). A este nivel, el NIST endurece los requisitos y **prohíbe de forma explícita** el uso de *passkeys* sincronizables. El cumplimiento del nivel AAL3 exige la utilización de credenciales vinculadas estrictamente al hardware físico del dispositivo (*device-bound keys*), operando bajo la premisa de que la clave criptográfica privada reside en un módulo aislado y es tecnológicamente no exportable ni clonable bajo ninguna circunstancia.

5.4 Fundamentos de la Arquitectura de Seguridad Moderna (OAuth 2.0 y OIDC)

En el contexto del desarrollo de *software* basado en arquitecturas distribuidas, APIs y microservicios, el módulo responsable de la autenticación se encuentra, por diseño, desacoplado lógicamente de los servicios de negocio. Para gestionar este flujo de delegación de acceso, los protocolos estándar de la industria son **OAuth 2.0** (un marco de trabajo para la delegación de autorización) y **OpenID Connect (OIDC)** (una capa de identidad construida sobre OAuth 2.0 para estandarizar la autenticación).

- **JSON Web Tokens (JWT):** Para maximizar el rendimiento y la escalabilidad, las aplicaciones web y móviles modernas han abandonado las sesiones tradicionales basadas en estado almacenadas en el servidor (que consumen memoria y complican el

balanceo de carga). En su lugar, utilizan arquitecturas sin estado (*stateless*). Tras validar las credenciales o el *passkey* del usuario, el servidor de identidad emite un *token* JWT firmado criptográficamente. Este *token* contiene en su carga útil (*payload*) las afirmaciones o reclamaciones (*claims*) sobre la identidad del usuario y sus permisos. El cliente adjunta este JWT en los encabezados HTTP de las peticiones posteriores, permitiendo que cualquier microservicio valide matemáticamente la autenticidad y la integridad de la solicitud verificando la firma del *token*, sin necesidad de realizar consultas sincrónicas y costosas a la base de datos central.

- **El Flujo OAuth 2.0 Authorization Code con PKCE:** En el pasado, los clientes públicos (como las aplicaciones móviles nativas y las SPA - *Single Page Applications* en JavaScript) sufrían vulnerabilidades críticas porque no podían almacenar de manera segura el "secreto del cliente" (*client_secret*) necesario para el flujo estándar de OAuth. Esto permitía a aplicaciones maliciosas instaladas en el mismo dispositivo interceptar el código de autorización a través del registro de esquemas de URL personalizados en el sistema operativo. La solución arquitectónica, y el estándar obligatorio en 2025 para todo tipo de clientes (incluyendo aplicaciones de escritorio y servidores back-end), es la inclusión de la extensión **PKCE** (*Proof Key for Code Exchange*). El mecanismo PKCE mitiga radicalmente el riesgo de interceptación inyectando entropía dinámica: antes de iniciar el flujo de inicio de sesión, la aplicación cliente genera aleatoriamente una cadena criptográfica (el *code_verifier*) y envía al servidor de autorización únicamente su valor calculado mediante una función *hash* SHA-256 (el *code_challenge*). Cuando el cliente intenta intercambiar el código de autorización por el *token* de acceso definitivo (el JWT), debe revelar el *code_verifier* original. El servidor verifica que el *hash* de este verificador coincida con el *challenge* presentado inicialmente. Puesto que un atacante que intercepte el código no conocerá el *verifier* oculto en la memoria del cliente legítimo, el ataque fracasará invariablemente.

5.5 Observabilidad en la Ciberseguridad: Más Allá del Monitoreo con OpenTelemetry y eBPF

Como se elaboró en la descripción del problema, la detección temprana de amenazas en entornos de *software* contemporáneos está limitada por el "abismo semántico". Las organizaciones están migrando de un enfoque de monitoreo rudimentario hacia el paradigma de la **Observabilidad**.

La diferencia no es meramente semántica; es una distinción fundamental en la arquitectura de sistemas. Mientras que el monitoreo se basa en la recopilación reactiva de métricas conocidas para confirmar la salud general del sistema, la observabilidad es una propiedad inherente a un sistema diseñado desde su concepción para permitir que su estado interno sea diagnosticado y comprendido analizando el contexto rico de sus salidas externas. La observabilidad en seguridad de aplicaciones se fundamenta en los cuatro pilares del marco MELT (*Metrics, Events, Logs, Traces* - Métricas, Eventos, Registros y Trazas).

El ecosistema de observabilidad en 2025 está dominado por la confluencia de dos tecnologías transformadoras: OpenTelemetry y eBPF.

- **OpenTelemetry (OTel):** Es un marco de trabajo de código abierto estandarizado y respaldado por la *Cloud Native Computing Foundation* (CNCF). Su objetivo es proporcionar un conjunto universal y agnóstico al proveedor (vendor-neutral) de APIs, bibliotecas (SDKs) y agentes para la recolección estandarizada de datos telemétricos. La

innovación crítica de OTel en el ámbito de la seguridad reside en la **trazabilidad distribuida**. OTel inyecta un identificador de contexto único (*TraceID*) en el punto exacto de entrada de una petición de usuario (por ejemplo, el *click* en el botón de "Iniciar Sesión"). Este identificador se propaga a través de las cabeceras de red por cada microservicio, base de datos y componente de infraestructura que participa en la resolución de esa petición. Esto permite reconstruir la historia cronológica exacta de una transacción compleja, dotando al equipo de seguridad de la visibilidad necesaria para comprender el flujo lógico de un ataque.

- **eBPF (Extended Berkeley Packet Filter):** eBPF es una tecnología revolucionaria integrada de forma nativa en el núcleo (*kernel*) del sistema operativo Linux (y en rápido proceso de adopción en plataformas Windows). En las arquitecturas tradicionales de seguridad y monitoreo, las herramientas deben ejecutarse como procesos en el espacio de usuario (*user space*), obligando al sistema a realizar costosos y continuos cambios de contexto (*context switches*) para transferir los paquetes de red o los datos de eventos desde el *kernel* hacia el nivel de aplicación. Esto induce cuellos de botella severos en el rendimiento.
    - **Ejecución Segura en el Kernel:** eBPF altera este paradigma permitiendo a los ingenieros inyectar y ejecutar programas personalizados directamente dentro del núcleo del sistema operativo de manera dinámica, sin necesidad de recompilar el *kernel* ni cargar módulos potencialmente inestables. Estos programas eBPF son sometidos a una estricta verificación previa por una máquina virtual interna para garantizar que no causarán el colapso del sistema ni introducirán vulnerabilidades de memoria.
    - **Instrumentación de Cero Código (*Zero-Code Instrumentation*):** Desde la perspectiva de la seguridad, el valor estratégico incalculable de eBPF es su capacidad para capturar llamadas al sistema (*syscalls*), eventos de red a nivel de paquete y operaciones de disco con una sobrecarga de procesamiento prácticamente insignificante (estudios demuestran reducciones de carga de CPU de hasta 210 veces comparado con agentes tradicionales en espacio de usuario). Crucialmente, la adopción de herramientas emergentes como OBI (*OpenTelemetry eBPF Instrumentation*) permite observar el comportamiento de red y las peticiones de las aplicaciones sin requerir que los desarrolladores modifiquen, recompilen o añadan dependencias de código a la lógica de negocio subyacente.

Característica Diferencial	Monitoreo Tradicional	Observabilidad Profunda (OTel + eBPF)
Enfoque Operacional	Reactivo y sintomático: Indica "Qué ocurrió" o emite alertas de que "El sistema falló".	Proactivo y causal: Revela "Por qué falló" permitiendo el análisis de la causa raíz.
Alcance de la Visibilidad	Limitada a métricas de infraestructura predefinidas y registros (*logs*) locales aislados.	Visibilidad distribuida y correlacionada (Trazas) y captura a nivel del *Kernel* de red sin alterar el código fuente.
Resolución de Problemas	Altamente efectivo para identificar problemas recurrentes y fallos conocidos ("knowns").	Fundamental para investigar fallos complejos y correlacionar vectores de ataque novedosos ("unknown unknowns").
Aplicación en Ciberseguridad	Limitada a la detección de	Permite el análisis de

Característica Diferencial	Monitoreo Tradicional	Observabilidad Profunda (OTel + eBPF)
	anomalías volumétricas obvias (ej. ataques DDoS) y bloqueos IP rudimentarios.	comportamiento en microsegundos, la detección de exfiltración de datos y el perfilado avanzado de atacantes persistentes.

6 Propuesta de solución: Arquitectura Integrada de Autenticación y Observabilidad

Para mitigar proactivamente los desafíos expuestos en la caracterización del problema y cumplir con los preceptos del marco teórico, la presente propuesta plantea la adopción de un ecosistema arquitectónico de "Seguridad por Diseño" (*Secure by Design*). En este modelo, la implementación del flujo de inicio de sesión se adapta minuciosamente a las particularidades de seguridad impuestas por cada plataforma cliente (Web, Móvil, Escritorio), mientras que la infraestructura de *backend* despliega una malla de observabilidad profunda (*Deep Observability*) que alimenta en tiempo real a los motores analíticos de prevención de fraude.

6.1 Implementación Criptográfica del Inicio de Sesión Seguro por Plataforma

Las consideraciones y los vectores de amenaza varían drásticamente dependiendo del entorno de ejecución de la aplicación cliente. Esta divergencia arquitectónica obliga a los ingenieros a adoptar estrategias asimétricas para la gestión segura de las credenciales, el cifrado y la mitigación de los riesgos catalogados en el OWASP Top 10.

6.1.1 Aplicaciones Web y Arquitecturas de Navegador

Las aplicaciones web operan inherentemente en un entorno hostil: los navegadores de los usuarios, donde se descarga y ejecuta código (JavaScript) potencialmente no confiable y donde la superficie de ataque es propensa a inyecciones de código. Las vulnerabilidades predominantes en este entorno son el *Cross-Site Scripting* (XSS) y la Falsificación de Petición en Sitios Cruzados (CSRF).

- **Adopción de WebAuthn para inicio de sesión sin contraseñas:** La arquitectura debe implementar la API de WebAuthn para registrar los dispositivos locales de los usuarios (sensores biométricos de computadoras portátiles, llaves FIDO conectadas por USB) como *passkeys* de primera línea. Para garantizar la inclusión de usuarios que operen en dispositivos heredados o no compatibles con enclaves biométricos, el sistema debe soportar un esquema de MFA adaptativo. Este mecanismo evalúa en tiempo real señales de riesgo colaterales (reputación de la dirección IP, velocidad de escritura, huella digital del navegador) para determinar el nivel de fricción necesario.
- **Gestión inexpugnable de sesiones:** Un error crítico de arquitectura frecuente en el desarrollo moderno es el almacenamiento de *tokens* JWT directamente en el almacenamiento local del navegador (localStorage o sessionStorage). Esta práctica permite que cualquier *script* malicioso inyectado (vía ataque XSS) lea la memoria local, exfiltre el *token* hacia un servidor controlado por el atacante y secuestre la sesión válida.

La arquitectura web segura de 2025 exige la utilización del patrón BFF (*Backend-for-Frontend*) o, en su defecto, el almacenamiento exclusivo de los *tokens* JWT de sesión en *cookies* HTTP fuertemente configuradas con los atributos de seguridad HttpOnly (que bloquea el acceso al *token* mediante JavaScript), Secure (que obliga la transmisión de la *cookie* únicamente sobre canales cifrados TLS), y SameSite=Strict (que instruye al navegador a no adjuntar la *cookie* en peticiones originadas desde dominios cruzados, neutralizando eficazmente los ataques CSRF).

- **Defensa Perimetral de Capa 7:** Es mandatorio el despliegue de políticas de encabezados de seguridad HTTP estrictas. Esto incluye la exigencia de conexiones cifradas mediante Transport Layer Security (TLS 1.3), erradicando el uso de protocolos criptográficos obsoletos, y la activación de HSTS (*HTTP Strict Transport Security*) para prevenir ataques de degradación de protocolo o *downgrade*. Asimismo, se debe configurar una Política de Seguridad de Contenido (CSP - *Content Security Policy*) restrictiva que dicte de manera determinista desde qué orígenes lógicos el navegador está autorizado a cargar y ejecutar *scripts* externos.

6.1.2 Aplicaciones Móviles Nativas (iOS y Android)

El ecosistema de aplicaciones móviles combina la conectividad ininterrumpida y persistente con la exposición inherente de *hardware* que puede ser robado físicamente o conectado a redes inalámbricas no confiables y monitoreadas (redes Wi-Fi públicas y puertos de carga adulterados). El OWASP Mobile Top 10 subraya específicamente el almacenamiento inseguro de datos locales y el uso inapropiado o inexperto de las plataformas del sistema operativo como vulnerabilidades de nivel crítico.

- **Validación de Plataforma y Almacenamiento Respaldado por Hardware:** En el paradigma de desarrollo para el año 2025, el proceso de inicio de sesión en clientes móviles debe aprovechar, de manera obligatoria y nativa, las capacidades del *hardware* criptográfico embebido en el dispositivo móvil (típicamente el *Secure Enclave* en el ecosistema Apple, o el *Trusted Execution Environment / Titan M* en arquitecturas Android). Las credenciales de sesión prolongada, especialmente los *tokens* de actualización (*refresh tokens*) con largos periodos de validez, deben almacenarse de forma exclusiva en la API del *Keychain* (iOS) o el *Keystore* (Android). Estos repositorios proporcionan un esquema de cifrado de datos en reposo que es avalado por *hardware*, asegurando que los secretos lógicos no puedan ser extraídos en texto plano incluso si el dispositivo móvil sufre un compromiso completo a nivel de *root* (o un proceso de *jailbreak / rooting*).
- **Autenticación Biométrica Integrada para Desbloqueo de Secretos:** Para mitigar el riesgo de acceso físico no autorizado por parte de terceros cuando un dispositivo móvil se encuentra temporalmente desbloqueado, las aplicaciones deben ser configuradas para solicitar autenticación biométrica local (FaceID, TouchID, o reconocimiento de iris) como precondición obligatoria antes de autorizar el desbloqueo criptográfico de los *tokens* almacenados en el *hardware* para iniciar una nueva sesión interactiva.
- **Seguridad Inflexible de la Capa de Transporte:** Para neutralizar los crecientes ataques de interceptación AiTM (Adversario en el Medio) orquestados por ciberdelincuentes en redes públicas o corporativas comprometidas, la arquitectura de la aplicación móvil debe implementar la técnica de fijación de certificados (*Certificate Pinning*). Esta técnica restringe la comunicación de la aplicación, indicándole que rechace la conexión a menos que el certificado TLS presentado por el servidor de autorización coincida exactamente

con un conjunto específico de claves públicas o *hashes* embebidos directamente y de antemano en el binario compilado de la aplicación cliente.

6.1.3 Aplicaciones de Escritorio Nativas e Infraestructura

A pesar de la abrumadora ubicuidad y el progreso de las arquitecturas basadas en tecnologías web, las aplicaciones de escritorio nativas (desarrolladas en C++, Rust o mediante ecosistemas administrados como el *framework*.NET) persisten fuertemente por razones fundamentales de rendimiento en tiempo real, requerimientos de procesamiento exhaustivo o integración a muy bajo nivel con los controladores del sistema operativo.

- **Protección de la Memoria y Almacenamiento Local de Secretos:** Históricamente, las aplicaciones de escritorio han sido particularmente vulnerables a técnicas avanzadas de ingeniería inversa, ataques de inyección de código dinámico en bibliotecas compartidas (DLLs) y, sobre todo, al raspado y robo directo de credenciales remanentes en la memoria volátil utilizando herramientas especializadas como *Mimikatz* o volcados de memoria arbitrarios. En este escenario, el almacenamiento en disco o en la caché de *tokens* de acceso debe eludir el uso de texto plano o algoritmos propios deficientes. Los ingenieros deben emplear invariablemente las API criptográficas provistas de manera nativa por el sistema operativo anfitrión. En entornos Microsoft, esto implica el uso de la API de Protección de Datos (*Data Protection API* - DPAPI), la cual cifra los datos del programa vinculándolos de forma transparente a la entropía de las credenciales de inicio de sesión de la sesión local activa del usuario en Windows; en el ecosistema de macOS, se debe recurrir al sistema *Keychain Access*.
- **Integración con Arquitecturas de Virtualización del Sistema Operativo:** Para despliegues en redes corporativas robustas (operando sistemas como Windows Server 2025 o estaciones Windows 11 Enterprise), las aplicaciones críticas deben diseñarse para aprovechar y soportar características avanzadas de seguridad basadas en la virtualización del *hardware*. Mecanismos como *Credential Guard* utilizan componentes de hipervisor para aislar lógicamente los procesos que manejan secretos de autenticación (como NTLM o Kerberos) dentro de un contenedor seguro. Esta barrera garantiza que ni siquiera procesos de *malware* o atacantes internos que hayan logrado elevar sus privilegios a un nivel administrativo completo (*SYSTEM* o *root*) puedan leer o exfiltrar los *hashes* o secretos de autenticación que residen en esa región protegida de la memoria del computador.
- **Marco de Autorización Resistente a Interceptación:** A pesar de que las aplicaciones de escritorio son procesos compilados y nativos, su interacción con proveedores de identidad externos debe adherirse de manera irreductible al uso del flujo **OAuth 2.0 Authorization Code con PKCE**. Históricamente, las aplicaciones de escritorio dependían del registro en el sistema operativo de manejadores de URL personalizados (*Custom URI Schemes*) para recibir el código de redirección desde el navegador tras un inicio de sesión. Esta arquitectura es vulnerable; un *malware* instalado en la misma máquina podría alterar el registro del sistema operativo para "secuestrar" el URI personalizado, robar el código de autorización y suplantar a la aplicación original. La utilización forzosa de PKCE por parte del cliente nativo inyecta el requerimiento del *code_verifier* generado dinámicamente, asegurando que cualquier atacante que intente interceptar o secuestrar el URI fracasará al intentar canjear el código robado, pues desconoce el secreto efímero original almacenado en la memoria segura del proceso de la aplicación de escritorio legítima.

6.2 Integración Profunda de Telemetría y Observabilidad para la Detección Activa de Amenazas

La arquitectura de defensa de una aplicación no concluye, ni mucho menos, en el momento en que el usuario introduce sus credenciales o aprueba el desafío biométrico de su *passkey*. El ecosistema de *software* debe poseer la capacidad endémica de observar de manera continua y crítica el comportamiento del usuario en la fase de posautenticación, contando con la autonomía para intervenir y reaccionar —por ejemplo, invalidando sesiones— si se detecta actividad indicativa de un compromiso. La propuesta teórica delineada en este apartado integra armónicamente la estandarización de OpenTelemetry (OTel) con la visión penetrante y de bajo consumo de eBPF, creando un canal ("pipeline") de observabilidad de seguridad continuo y determinista, que opera de forma paralela sin introducir cuellos de botella apreciables en el rendimiento transaccional de las aplicaciones comerciales.

6.2.1 Implementación de OpenTelemetry para la Trazabilidad Estructural del Negocio

Se propone como mandato arquitectónico instrumentar el código de los microservicios centrales —especialmente aquellos relativos a la gestión de identidad y acceso (sistemas IAM)— incorporando las bibliotecas o SDKs oficiales de OpenTelemetry. Esta instrumentación es vital para tejer y correlacionar lógicamente los eventos generados a lo largo de un ecosistema distribuido.

- En el flujo propuesto, cuando un usuario inicia una interacción (independientemente de si la solicitud se emite desde un terminal móvil, una interfaz web en el navegador, o un sistema de escritorio), el *Gateway* de la Interfaz de Programación de Aplicaciones (API) intercepta la petición entrante y genera de forma automática un identificador global y único denominado TraceID. Este TraceID se inyecta en el contexto de la solicitud y viaja a través de todas las transacciones, componentes intermedios y llamadas RPC (*Remote Procedure Call*) subsecuentes.
- Desde el punto de vista del equipo de operaciones de seguridad (SecOps), esta arquitectura permite a los analistas rastrear y desentrañar con precisión forense la ruta temporal y causal de las acciones. Si, de manera hipotética, un usuario logra autenticarse exitosamente en el servidor IAM, pero la plataforma de observabilidad detecta de inmediato que el mismo TraceID asociado a esa sesión se invoca para comunicarse repetidamente con un microservicio de respaldo o base de datos profunda, solicitando de forma iterativa y masiva descargar el histórico de registros de tarjetas de crédito o información privilegiada (un comportamiento atípico para el perfil de ese usuario), la plataforma de observabilidad centralizada, correlacionando en tiempo real las trazas y la identidad, puede elevar automáticamente una alerta crítica, infiriendo una posible escalada de privilegios o un escenario inminente de filtración y exfiltración de datos corporativos.

6.2.2 Implementación de Sensores eBPF para la Garantía de Seguridad en Tiempo de Ejecución (*Runtime Security*)

Mientras que OpenTelemetry provee el mapa de la trazabilidad a nivel de la capa de aplicación

y la lógica de negocio, la tecnología eBPF asume el rol de un monitor omnisciente, silencioso y de extrema velocidad, anidado directamente en las profundidades del núcleo (*kernel*) del sistema operativo de los servidores.

- **Monitoreo sin Alteración de Código (*Zero Modification Monitoring*):** La inserción de sensores eBPF (haciendo uso de implementaciones reconocidas en la industria tales como OBI —*OpenTelemetry eBPF Instrumentation*— o la plataforma Tetragon) se realiza adjuntando programas microscópicos a puntos de anclaje (*tracepoints* o *kprobes*) específicos dentro del código del kernel. Estos sensores, que operan a un nivel inferior al de la máquina virtual o el contenedor de la aplicación, tienen la capacidad técnica de observar y analizar cada conexión TCP iniciada, cada solicitud de resolución de nombres DNS y cada llamada fundamental al sistema (*syscall*) solicitada por los procesos y contenedores que alojan la lógica y los secretos del servicio de autenticación corporativo. Esta aproximación garantiza que la recolección telemétrica no interfiera con el ciclo de vida del desarrollo de la aplicación y que sea efectiva incluso frente a componentes de código cerrado, infraestructuras *legacy* o aplicaciones encapsuladas provistas por terceros, sobre las cuales el equipo de ingeniería interna no tiene control a nivel de código fuente.
- **Detección de Anomalías e Intrusiones Profundas:** En la desafortunada eventualidad de que un atacante experto logre evadir los controles iniciales, comprometer el microservicio encargado de la autenticación e intente explotar la vulnerabilidad para lanzar una *shell* de comandos interactiva remota, ejecutar *scripts* no autorizados, o modificar subrepticiamente componentes sensibles del sistema de archivos (como inyectar un acceso por puerta trasera alterando archivos críticos de la distribución Linux), los programas eBPF actúan como una trampa ineludible. Estos sensores interceptan las llamadas al sistema correspondientes de manera determinista y en fracciones ínfimas de microsegundos antes de que se consume la instrucción de bajo nivel, procediendo a exportar las métricas de alerta de seguridad y la telemetría asociada hacia la central de control o un sistema SIEM (*Security Information and Event Management*) configurado.
- **Análisis y Correlación Criptográfica Avanzada:** Una de las características más disruptivas de la tecnología eBPF en el entorno de observabilidad moderna es su facultad de ser programado para interceptar subrutinas en el espacio del núcleo, logrando leer o inspeccionar el estado de los paquetes de datos justo antes de que estos sean encapsulados y cifrados por los algoritmos TLS/SSL (Transport Layer Security) al abandonar el proceso del servidor, o inmediatamente después de que los paquetes entrantes cifrados son descifrados en el entorno seguro. Esta inspección pre/post-cifrado de las transacciones confiere a los analistas la certeza total de que ninguna carga útil maliciosa o exfiltración encubierta (*malware payload*) logre pasar inadvertida al ocultarse hábilmente dentro de canales de comunicación aparentemente lícitos y cifrados de la empresa.

6.2.3 Prevención Proactiva de la Toma de Control de Cuentas (ATO) mediante Analítica Avanzada e Inteligencia Artificial

La ingente y masiva cantidad de datos estandarizados, trazas, registros y métricas de alta fidelidad recopilados conjuntamente por las sondas de OpenTelemetry y los programas de eBPF, son canalizados de manera centralizada y alimentan motores complejos impulsados por técnicas de analítica de comportamiento y modelos predictivos de aprendizaje automático o Inteligencia Artificial (IA). Esta convergencia tecnológica de última generación, donde la

infraestructura de observabilidad actúa como un vasto sistema nervioso sensorial y el modelo de IA funciona como un cerebro analítico correlacionador, permite a la arquitectura de defensa actuar en dos frentes cruciales:

1. **Identificación Temprana y Detención de *Credential Stuffing*:** El motor de IA, impulsado por el flujo de telemetría ininterrumpido a nivel de red suministrado por eBPF, puede ejecutar análisis volumétricos en tiempo de red extremadamente veloces, permitiendo al sistema discernir que, aunque aparentemente provengan de direcciones IP globales diversas, cientos o miles de transacciones de inicio de sesión individuales comparten, en realidad, patrones sutiles, métricas en la manipulación de encabezados HTTP, temporización o rastros que las delatan como un enjambre coordinado de la red oscura (*botnets* o *proxies* residenciales) orquestando un ataque de relleno de credenciales. La analítica es capaz de levantar las barreras dinámicas a nivel del *Firewall* de Aplicaciones Web (WAF) o descartar las sesiones temporalmente, protegiendo las credenciales comprometidas.
2. **Implantación Continua de Biometría de Comportamiento (*Behavioral Biometrics*):** El sistema va mucho más allá de verificar la identidad en el punto de ingreso (en la puerta de autenticación). Al procesar mediante inteligencia artificial el flujo constante de telemetría remitido desde la aplicación cliente —analizando métricas finas como la dinámica e idiosincrasia de los trazos, los micropatrones en la trayectoria y velocidad de desplazamiento del cursor del ratón, el ángulo con que se sostiene un dispositivo móvil o la cadencia microscópica de presión sobre el teclado físico—, los algoritmos son capaces de perfilar un modelo matemático conductual único para el usuario legítimo. En el transcurso de una sesión web, móvil o de escritorio abierta, la IA puede dictaminar que el comportamiento errático detectado súbitamente no corresponde con el humano perfilado, sino que coincide con la cadencia perfecta y las trayectorias antinaturales de un *script* automatizado o corresponde a las interacciones remotas de un intruso. Basado en esta certidumbre, el sistema de identidad procede a revocar inmediatamente los *tokens* JWT asociados o induce dinámicamente el requerimiento de presentar un nuevo reto de Autenticación Multifactor adaptativo, exigiendo validación biométrica facial para impedir daños colaterales.

7 Evaluación y Cumplimiento Normativo de la Arquitectura

La adopción estructural y el despliegue a producción de esta arquitectura avanzada e integral (centrada en el abandono progresivo de contraseñas mediante el estándar FIDO2 y las *passkeys*, combinada con una matriz analítica de observabilidad conformada por eBPF y OpenTelemetry) no solo aporta resoluciones pragmáticas a debilidades tecnológicas históricas. También es el mecanismo óptimo para demostrar y materializar la adhesión de la infraestructura corporativa a los marcos regulatorios internacionales y al corpus legislativo local aplicable.

7.1 Efectividad en la Mitigación Técnica de Riesgos (OWASP Top 10 y Amenazas Contemporáneas)

El cambio de paradigma hacia una filosofía de autenticación sin contraseñas, erigida y

fundamentada sólidamente en el ecosistema criptográfico del estándar FIDO2 y la WebAuthn API, aborda y elimina de raíz el vector de ataque informático más extendido, peligroso y explotado a nivel global: la debilidad inherente a las prácticas humanas de reutilización, la predictibilidad, y la vulnerabilidad al *phishing* de las contraseñas estáticas. Esta innovación de arquitectura mitiga frontalmente y de forma directa el riesgo primario de las Fallas de Identificación y Autenticación, listadas imperativamente en el índice global OWASP Top 10 bajo la clasificación (A07:2021). De forma simultánea y colaborativa, el entrelazamiento de las metodologías modernas de observabilidad responde directamente, subsana y anula el riesgo definido por OWASP como Fallas Críticas en el Registro y Monitoreo de Seguridad (A09:2021). La captura precisa y autónoma de la telemetría proveniente del mismísimo núcleo de procesamiento de red (vía el *framework* eBPF) asegura categóricamente que en las infraestructuras de microservicios contenerizadas —que por naturaleza son altamente dinámicas, cambiantes y efímeras— no subsistan áreas sin monitorizar o "puntos ciegos" estructurales. La arquitectura genera en tiempo real una riqueza y densidad de información contextual que representa la evidencia digital y forense indispensable, operando así como la piedra angular técnica exigida por cualquier modelo validado de confianza cero o *Zero Trust*.

7.2 Transición y Adherencia Proactiva a los Lineamientos Federales del NIST SP 800-63-4 (Edición 2025)

La propuesta de *software* esbozada es sustancialmente armónica y plenamente compatible con las drásticas actualizaciones normativas y de buenas prácticas promulgadas recientemente en la Cuarta Revisión (2025) de las Directrices de Identidad Digital publicadas por el influyente Instituto Nacional de Estándares y Tecnología de los EE.UU (NIST). Las directrices contemporáneas conminan a los sectores industriales a ejecutar un abandono perentorio y estructurado del uso de redes de telecomunicaciones (como códigos PIN enviados por medio de SMS) y la migración obligada hacia arquitecturas algorítmicamente resistentes al *phishing*, instaurando la adopción temprana de *passkeys* como la nueva norma y la línea base de ciberseguridad inamovible requerida para alcanzar el Nivel de Garantía de Autenticación AAL2. De igual forma, en escenarios de misión crítica, infraestructura fundamental o transacciones financieras de alto riesgo, donde el NIST impone las rigurosas exigencias englobadas en la escala máxima AAL3, la arquitectura aquí delimitada se ajusta de manera integral: segrega la inicialización y ejecución criptográfica asimétrica a los niveles más bajos de la arquitectura local de dispositivos finales. Emplea la aislación basada en silicio mediante la integración con microchips de protección criptográfica endurecidos (como lo son el chip *Trusted Platform Module* - TPM y el *Secure Enclave* en los ecosistemas de movilidad inteligente de Apple, o el hardware TPM en estaciones de trabajo y ecosistemas Windows Server), lo que garantiza de manera demostrable que el cifrado es nativo y que las claves privadas permanecen inalterables e inexportables hacia redes o procesos de nivel superior.

7.3 Alineación Estricta y Cumplimiento del Marco Legislativo en el Estado Colombiano (Leyes 1273 de 2009 y 1581 de 2012)

El análisis desde la trascendente perspectiva legal subraya que la implantación de tecnologías disruptivas, eficientes y seguras desde el núcleo como el conjunto eBPF, genera, custodia y entrega de forma autónoma un registro documental que es por definición exhaustivo, temporalmente inalterable e incorruptible, respecto a las interacciones, secuencias del sistema,

flujos de tráfico a nivel de paquetes de red y la conducta subyacente del *kernel* de los servidores involucrados. En el lamentable escenario de que se detecte e investigue o se llegue a materializar efectivamente la tipificación penal de una conducta ilícita definida por el Código Penal colombiano como el "acceso abusivo a un sistema informático" (estipulado con severidad bajo el marco del Artículo 269A de la fundamental Ley 1273 de Delitos Informáticos) , es precisamente esta matriz telemétrica la que habilitará técnica, pericial y jurídicamente la rápida formulación, encapsulamiento y preservación de una cadena de custodia sólida para ser entregada en formato de evidencia digital forense irrefutable a las dependencias policiales, a la Fiscalía General de la Nación, o al CAI Virtual especializado en Cibercrimen de la Policía Nacional de Colombia; configurando este proceder un requerimiento procesal vital y frecuentemente inalcanzable para que la investigación del delito cibernético en Colombia prospere legalmente. De forma sinérgica, holística y adicional, el diseño riguroso y exhaustivo de esta propuesta arquitectónica y sus flujos algorítmicos aseguran la protección diligente a lo largo de todo el ciclo de vida del tratamiento, tránsito y almacenamiento de cualquier dato personal vinculado al proceso de identidad de los ciudadanos, respaldando sólidamente el cumplimiento del derecho inalienable al Habeas Data reglamentado por la Ley Estatutaria 1581.
Al transitar el ecosistema empresarial del estado del arte anterior hacia el diseño moderno soportado en la tecnología FIDO2, el paradigma es claro: los servidores, repositorios corporativos y redes de bases de datos dejan definitivamente de recolectar, almacenar y resguardar en texto plano, *hash*, o de cualquier otro modo las contraseñas, los secretos compartidos vulnerables o las matrices biométricas únicas (huellas o rostros de los usuarios) de la ciudadanía; evitando consiguientemente que dichos datos sensibles y de altísimo riesgo queden permanentemente vulnerables y a merced de posibles eventos desastrosos originados por la exfiltración furtiva de bases de datos centralizadas en la nube corporativa.

8 Conclusiones

La disciplina y las operaciones de la ciberseguridad para el año 2025 y más allá ya no pueden sustentarse operativa ni conceptualmente en la suposición arcaica y demostradamente ineficaz de que los ecosistemas de información internos, las bases de datos y los procesos de aplicación se hallan a salvo en la cómoda protección resguardada detrás de una barrera de cortafuegos o un perímetro de enrutamiento físico delimitado. Con la disolución irrevocable de las redes estáticas, el proceso metodológico y estructural del inicio de sesión interactivo y las comprobaciones de autorización se han transformado inexorablemente en el epicentro medular y el primer frente en el campo de batalla del control de accesos de la información. Este axioma constituye el núcleo de un entorno sustentado obligatoriamente en los principios operativos de Confianza Cero (*Zero Trust Architecture*).
El análisis académico y exhaustivo de las directrices y las tecnologías consolidadas que gobiernan la informática actual demuestra de forma inequívoca que la eliminación técnica y progresiva, pero definitiva, de la dependencia de las contraseñas estáticas es un mandato imperativo. La industria, liderada por consorcios como el W3C y FIDO Alliance, converge unánimemente hacia la adopción masiva de mecanismos de validación sustentados en el emparejamiento de credenciales criptográficas asimétricas. El uso preferente de los *passkeys*, combinados con implementaciones arquitectónicas avanzadas de Autenticación Multifactor (MFA) estructuralmente inmunes e insensibles a las ramificaciones técnicas de los engaños por *phishing* de proxy inverso, constituye el trayecto tecnológico unificado, normativo, legal y procedimentalmente obligatorio que debe recorrerse. Únicamente de esta forma es posible

blindar integralmente a los ecosistemas dispares que abarcan y engloban a los clientes en las aplicaciones *web* reactivas, los dispositivos y teléfonos móviles inherentemente expuestos y las plataformas de procesamiento de escritorio intensivo y nativo de las empresas corporativas. La erradicación del secreto compartido asfixia de raíz a uno de los negocios criminales cibernéticos más voluminosos de la economía ilícita global: el comercio de credenciales filtradas y el masivo incremento automatizado de ataques orquestados de suplantación técnica y las ofensivas sistemáticas de *credential stuffing* (o de inyección masiva de contraseñas recicladas).

No obstante, en un mundo interconectado asimétricamente, la implantación por sí sola de un flujo de autenticación reforzado, inmutable y robusto representa únicamente el eslabón de apertura en la cadena de seguridad requerida de punta a punta. Dada la complejidad enmarañada de los servicios expuestos, la volatilidad de la arquitectura de contenedores subyacentes, las ramificaciones extensas de las infraestructuras sustentadas en miles de microservicios fragmentados en lenguajes políglotas y los enormes ecosistemas diseminados dinámicamente en múltiples dominios geográficos en la nube de proveedores globales; la simplicidad reduccionista basada en el limitado monitoreo visual de disponibilidad y umbrales volumétricos predefinidos ha caducado irreparablemente.

La integración estructural y programática de un modelo analítico de observabilidad omnipresente (como el explorado mediante la asimilación del estándar de la industria abierto OpenTelemetry para materializar y correlacionar una trazabilidad distribuida e individualizada en cada transacción, operando sin fricción ni obstáculos combinadamente con las utilidades de vigilancia de introspección determinista, asombrosamente ligera, imperceptible, inquebrantable y microscópica del mismísimo *kernel* nativo habilitadas a través del despliegue del conjunto lógico de programas seguros en eBPF) posibilita y le confiere innegablemente el superpoder algorítmico, a las diferentes compañías y a los arquitectos defensivos modernos de los Sistemas de la Información, de inferir, correlacionar automáticamente en milisegundos y aislar cada uno de los eventos esporádicos o atípicos subyacentes desde la interfaz de los módulos y repositorios de autenticación, mapeándolos en correlación paralela e instantánea contra los subsiguientes cambios inesperados o maliciosos evidenciados de forma silenciosa e invisible en el núcleo primario del comportamiento operativo base del entorno del *software* empresarial interno.

Esta sinergia técnica sin precedentes, que conjuga a la más fuerte barrera criptográfica conocida frente al robo de identidad humana en comunión con una ventana telemétrica iluminada en vivo para capturar de manera silenciosa las mecánicas en la capa oculta del sistema operativo, transforma sustancialmente la endeble e histórica postura de la seguridad informática (acostumbrada y circunscrita al estado perjudicialmente reactivo e *a posteriori*) y la transporta proactivamente hacia los niveles óptimos esperados del control, anticipación, e invulnerabilidad resiliente. Esta propuesta metodológica en la disciplina formativa moderna de la ingeniería de la seguridad digital garantiza la rápida y eficaz detección microscópica de anomalías lógicas, certifica irrefutablemente el acatamiento pleno y auditado en cumplimiento exigido de los estamentos jurídicos y penales tipificados como regulaciones por el Estado Colombiano en las estrictas directrices reglamentadas mediante las históricas normativas que componen la Ley Estatutaria de Protección y Tratamiento del Dato Personal 1581 de 2012 y la Ley Penal de Delitos Informáticos, Manipulación y Acceso Abusivo 1273 de 2009. Su correcta implementación asegura paralelamente a cualquier infraestructura o solución digital diseñada una armonización sistemática, de alineación integral y de acatamiento transversal con las especificaciones globales y los parámetros técnicos, marcos conceptuales normativos ISO internacionales dictaminados en el seno de la directriz gerencial del sistema de calidad en

seguridad ISO 27001, y la imperante vanguardia y dictamen federal del Instituto (NIST) contenida en su publicación de alcance regulador SP 800-63 de revisión actual.
En suma de este exhaustivo ejercicio en profundidad y perspectiva investigativa arquitectónica integral, la conjugación indivisible, metódica y acoplada que interrelaciona una gestión de identidades moderna basada rigurosamente en credenciales resistentes y la implantación de una canalización analítica para observar con una resolución infinita cada estrato profundo o superficial del aplicativo informático y sus capas superpuestas e interconectadas no puede comprenderse meramente como una innovación de tendencia aislada o un elemento accesorio que deba dejarse al criterio técnico particular de la optimización individual, sino que por peso normativo debe consolidarse obligatoriamente como un axioma, la única estrategia arquitectónica inamovible fundamental para la supervivencia digital que logre salvaguardar de forma definitiva y robusta el valor en los activos informáticos, organizacionales, civiles y del capital sensible depositado a nivel nacional en la crítica actual de la incierta era digital hiperconectada.

Obras citadas

1. A Review on Secure Authentication Mechanisms for Mobile Security - MDPI, https://www.mdpi.com/1424-8220/25/3/700 2. Additional 2025 DBIR research on credential stuffing - Verizon, https://www.verizon.com/business/resources/articles/credential-stuffing-attacks-2025-dbir-research/ 3. Account Takeover Statistics 2025: Key Trends & Insights - AuthX, https://www.authx.com/blog/account-takeover-fraud-statistics-insights/ 4. Passkeys Handbook 2025 | Secure, Passwordless Authentication with MojoAuth, https://mojoauth.com/white-papers/passkeys-passwordless-authentication-handbook/ 5. NIST SP 800-63-3 & 63-4: Digital Identity Guidelines - HYPR, https://www.hypr.com/blog/nist-sp-800-63-3-digital-identity-guidelines-review 6. Observability vs. Monitoring: What's the Difference? - New Relic, https://newrelic.com/blog/observability/observability-vs-monitoring 7. Observability vs. Monitoring: What's the Difference? - CrowdStrike, https://www.crowdstrike.com/en-us/cybersecurity-101/observability/observability-vs-monitoring/ 8. (PDF) eBPF-Enhanced Complete Observability Solution for Cloud-native Microservices, https://www.researchgate.net/publication/379891642_eBPF-Enhanced_Complete_Observability_Solution_for_Cloud-native_Microservices 9. Unveiling OpenTelemetry eBPF Instrumentation, https://horovits.medium.com/unveiling-opentelemetry-ebpf-instrumentation-377cb0432bf1 10. AgentSight: System-Level Observability for AI Agents Using eBPF - arXiv.org, https://arxiv.org/html/2508.02736v2 11. What Is User Authentication? A 2025 Guide for Modern Apps - Frontegg, https://frontegg.com/blog/authentication 12. Authentication Implementation at Scale: Developer's Guide 2025 - Deepak Gupta, https://guptadeepak.com/the-complete-guide-to-authentication-implementation-for-modern-applications/ 13. LEY 1273 DE 2009 - Armada Nacional, https://www.armada.mil.co/sites/default/files/normograma_arc/telematica/Ley%201273%20de%202009%20Modifica%20CP%20para%20protecci%C3%B3n%20de%20datos%20e%20informaci%C3%B3n.pdf 14. Ley 1581 de 2012 Congreso de la República de Colombia, https://www.alcaldiabogota.gov.co/sisjur/normas/Norma1.jsp?i=49981 15. Zero Trust Architecture in 2025: Shifting from Perimeter Security to “Never Trust, Always Verify” - Northern Technologies Group, https://ntgit.com/zero-trust-architecture-in-2025-shifting-from-perimeter-security-to-never-trust-al

ways-verify/ 16. Implementing a Zero Trust Architecture | NCCoE - NIST, https://www.nccoe.nist.gov/projects/implementing-zero-trust-architecture 17. Web App Security in 2025: 5 Technologies You Can't Do Without - Oligo, https://www.oligo.security/academy/web-app-security-in-2025-5-technologies-you-cant-do-without 18. How to actually stop credential stuffing in 2025 - Authsignal, https://www.authsignal.com/blog/articles/how-to-actually-stop-credential-stuffing-in-2025 19. White paper: The Future of Customer Authentication in 2025 - Prefactor, https://prefactor.tech/blog/future-of-customer-authentication 20. Observability vs. monitoring: What's the difference? - Dynatrace, https://www.dynatrace.com/news/blog/observability-vs-monitoring/ 21. Monitoring vs Observability in Cybersecurity | Key Differences - Huntress, https://www.huntress.com/cybersecurity-101/topic/monitoring-vs-observability 22. Security observability: Protecting against vulnerabilities and threats - New Relic, https://newrelic.com/blog/security/how-observability-helps-security 23. OpenTelemetry, https://opentelemetry.io/ 24. Observability trends in 2025 - InfluxData, https://www.influxdata.com/glossary/observability-trends-2025/ 25. Colombia enfrenta récord de 36.000 millones de ciberataques en 2024 | ACIS, https://www.acis.org.co/blog/noticias-2/colombia-enfrenta-record-de-36000-millones-de-ciberataques-en-2024-4964 26. Colombia fue víctima de 36 mil millones de intentos de ciberataques en 2024 - Infobae, https://www.infobae.com/tecno/2024/12/03/colombia-fue-victima-de-36-mil-millones-de-intentos-de-ciberataques-en-2024/ 27. balance de ciberseguridad 2023 - CAI Virtual - Policía Nacional de Colombia, https://caivirtual.policia.gov.co/sites/default/files/observatorio/Balance%20anual%202023_0.pdf 28. Kasada - 2025 Account Takeover Attack Trends Report, https://www.kasada.io/wp-content/uploads/2025/04/Kasada-2025-Account-Takeover-Attack-Trends-Report.pdf 29. Account Takeover (ATO): How Attacks Work & Prevention - Vectra AI, https://www.vectra.ai/topics/account-takeover 30. Passwordless Authentication Trends: Where We're Headed - Descope, https://www.descope.com/blog/post/passwordless-authentication-trends 31. Modern password security for system designers - Google Cloud Documentation, https://docs.cloud.google.com/solutions/modern-password-security-for-system-designers.pdf 32. Mobile Top 10 2024 - OWASP.org, https://owasp.org/www-project-mobile-top-10/ 33. What is OWASP? What is the OWASP Top 10? | Cloudflare, https://www.cloudflare.com/learning/security/threats/owasp-top-10/ 34. OWASP Top Ten 2024 – The Complete Guide - Reflectiz, https://www.reflectiz.com/blog/owasp-top-ten-2024/ 35. 10 Web Application Security Threats for 2025 & How to Respond - StackHawk, https://www.stackhawk.com/blog/10-web-application-security-threats-and-how-to-mitigate-them/ 36. Building Secure Authentication Layers: A Complete Guide for 2025 | Jaya Raj Srivathsav Adari, https://srivathsav.me/blog/building-secure-authentication-layers-2025 37. eBPF: A New Approach to Cloud-Native Observability, Networking and Security for Current (5G) and Future Mobile Networks (6G and - IEEE Xplore, https://ieeexplore.ieee.org/iel7/6287639/6514899/10138542.pdf 38. Architecture Best Practices for Azure App Service (Web Apps) - Microsoft Azure Well-Architected Framework, https://learn.microsoft.com/en-us/azure/well-architected/service-guides/app-service-web-apps 39. AgentSight: System-Level Observability for AI Agents Using eBPF - arXiv, https://arxiv.org/html/2508.02736v1 40. Colombia Ley N°1273 (modificación al Código Penal "protección de la información y los datos") - 2009 - CELE,

https://observatoriolegislativocele.com/colombia-ley-n1273-modificacion-al-codigo-penal-proteccion-de-la-informacion-y-los-datos-2009/ 41. Best Practices for Securing Web Applications in 2025 - DevsTree, https://www.devstree.com/best-practices-for-securing-web-applications/ 42. Normatividad sobre delitos informáticos - Policía Nacional de Colombia, https://www.policia.gov.co/normatividad-sobre-delitos-informaticos 43. política de protección de datos personales - Procuraduría General de la Nación, https://www.procuraduria.gov.co/Pages/pol%C3%ADticas-proteccion-datos.aspx 44. NIST Special Publication 800-63-4, https://pages.nist.gov/800-63-4/sp800-63.html 45. Phishing-Resistant MFA in 2025: Buyer's Guide to NIST SP 800-63-4 & OMB M-22-09, https://www.wwpass.com/blog/phishing-resistant-mfa-in-2025-buyer-s-guide-to-nist-sp-800-63-4-omb-m-22-09/ 46. Passwordless authentication in 2025: The year passkeys went mainstream - Authsignal, https://www.authsignal.com/blog/articles/passwordless-authentication-in-2025-the-year-passkeys-went-mainstream 47. The state of passkeys in 2025 - 1Password Community, https://www.1password.community/blog/random-but-memorable/the-state-of-passkeys-in-2025/163464 48. NIST SP 800-63 Digital Identity Guidelines, https://pages.nist.gov/800-63-4/ 49. Digital Identity Guidelines: Authentication and Authenticator Management - NIST Technical Series Publications, https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-63B-4.pdf 50. Observability vs. Monitoring: The Difference in Your IT Environment - TierPoint, https://www.tierpoint.com/blog/cloud/observability-vs-monitoring/ 51. OpenTelemetry and eBPF: Everything You Need to Know - Groundcover, https://www.groundcover.com/ebpf/opentelemetry-ebpf 52. Observability Trends in 2025 – What's Driving Change? | CNCF, https://www.cncf.io/blog/2025/03/05/observability-trends-in-2025-whats-driving-change/ 53. eBPF for the Infrastructure Platform - Linux Foundation, https://www.linuxfoundation.org/hubfs/eBPF/The_State_of_eBPF25_111925.pdf 54. An In-Depth Analysis of eBPF-Based System Security Tools in Cloud-Native Environments - IEEE Xplore, https://ieeexplore.ieee.org/iel8/6287639/10820123/11146725.pdf 55. OpenTelemetry eBPF Instrumentation, https://opentelemetry.io/docs/zero-code/obi/ 56. OpenTelemetry eBPF Instrumentation Marks the First Release, https://opentelemetry.io/blog/2025/obi-announcing-first-release/ 57. OWASP Secure by Design Framework, https://owasp.org/www-project-secure-by-design-framework/ 58. What is Application Security | Types, Tools & Best Practices | Imperva, https://www.imperva.com/learn/application-security/application-security/ 59. OWASP Juice Shop | OWASP Foundation, https://owasp.org/www-project-juice-shop/ 60. What's new in Windows Server 2025 | Microsoft Learn, https://learn.microsoft.com/en-us/windows-server/get-started/whats-new-windows-server-2025 61. Common Mobile Application Security Vulnerabilities 2025 - Touchlane, https://touchlane.com/common-mobile-application-vulnerabilities-2025/ 62. Security Testing in 2025: AI, Cloud Native, and More - Mend.io, https://www.mend.io/blog/security-testing-in-2025-testing-apps-ai-cloud-native-and-more/ 63. Why Desktop Applications Will Still Be in Demand in 2025 - Chudovo, https://chudovo.com/why-desktop-applications-will-still-be-in-demand/ 64. Desktop App Development: A Complete Guide for 2025 | by Jhavtech Studios | Medium, https://jhavtech.medium.com/desktop-app-development-a-complete-guide-for-2025-931d4fe354e4 65. 6 Best Practices for Secure Login Implementation in 2025 | by Richa Gautam, https://javascript.plainenglish.io/6-best-practices-for-secure-login-implementation-in-2025-738d6

b5cb1e6 66. Observability in 2025: OpenTelemetry and AI to Fill In Gaps - The New Stack, https://thenewstack.io/observability-in-2025-opentelemetry-and-ai-to-fill-in-gaps/ 67. How to Use eBPF with OpenTelemetry for Kernel-Level Observability - OneUptime, https://oneuptime.com/blog/post/2026-02-06-ebpf-opentelemetry-kernel-observability/view 68. Fraud Analytics in 2025: Why Traditional Systems Fail - CLEAR1, https://identity.clearme.com/post/fraud-analytics-2025-why-traditional-systems-fail 69. Understanding AI Fraud Detection and Prevention in 2026 | DigitalOcean, https://www.digitalocean.com/resources/articles/ai-fraud-detection 70. Balance de Ciberseguridad 2024: Desafíos y prevención para un entorno digital seguro, https://www.ccit.org.co/noticias/balance-de-ciberseguridad-2024-desafios-y-prevencion-para-un-entorno-digital-seguro/